



Treinamento em Segurança Ofensiva 2024/2025

Relatório de Atividades	
Módulo 4:	Pentest em Aplicações Web
Atividade 2:	Vulnerabilidades de Regra de Negócios
Nome:	Luiz Eduardo de Andrade

1. Introdução

Estas atividades fazem parte do módulo *Pentest em Aplicações Web*, para a qual utilizamos a sala do PortSwigger - <https://portswigger.net/>

No contexto desta sala, nosso foco é:

- 1) Utilizar a falha de validação de entrada de usuário para comprar um produto ao qual não tem saldo suficiente para comprar, mas devido a este erro consegue inserir número negativo para que o saldo fique menor que \$ 100 e consiga comprar um produto mais caro;
- 2) Exploraremos falhas sobre a sequência de eventos no fluxo de trabalho de compras, colocaremos no carrinho um produto com valor maior que o disponível para gastar e devido a falha sobre a sequência de eventos conseguiremos comprar este produto;
- 3) Temos uma falha lógica no fluxo de trabalho que vamos aproveitar, para através de um cupom de desconto aumentar nosso saldo e comprar qualquer produto que nos interesse;
- 4) Vamos utilizar a falha de validação de login, ignorando a autenticação, entrar na interface de administrador e excluir o usuário.

A sala do Portswigger é composta por quatro tarefas:

- 1) Vulnerabilidade lógica de alto nível: <https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws-high-level>
- 2) Validação de fluxo de trabalho insuficiente: <https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws-insufficient-workflow-validation>
- 3) Falha lógica de dinheiro infinito: <https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws-infinite-money>

4) Bypass de autenticação via máquina de estado com falha:
<https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws-authentication-bypass-via-flawed-state-machine>

2. Desenvolvimento

2.1. Configuração do ambiente

Os seguintes passos foram necessários para configurar o ambiente necessário para o desenvolvimento das atividades:

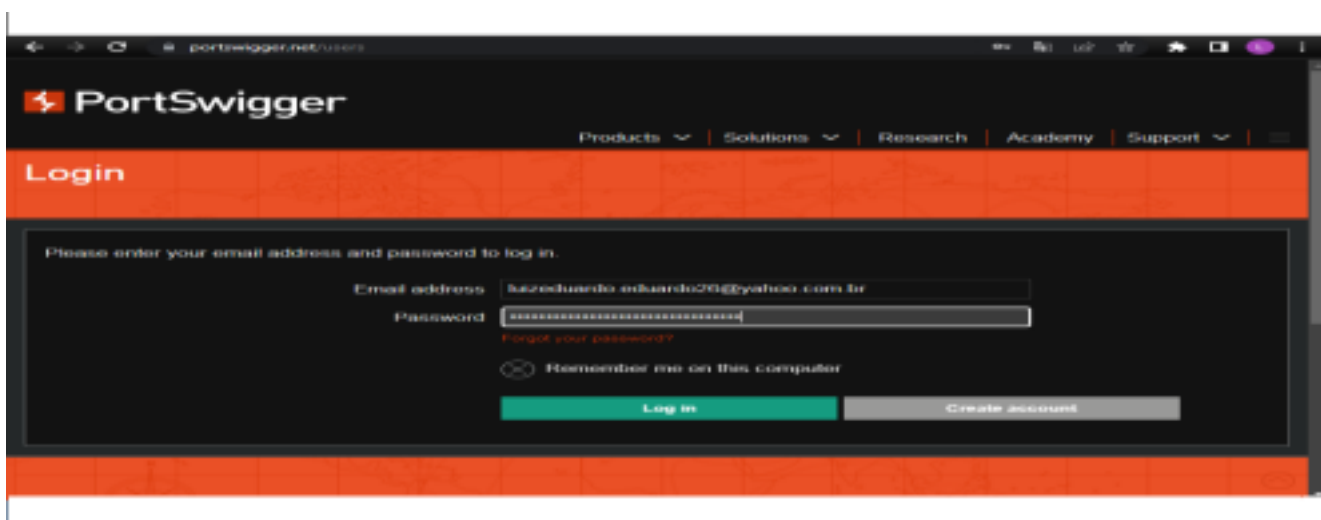
- 1) Acessar os sites informados acima.
- 2) Utilizar a VM do Kali Linux: Para utilizar o Burp e executar alguns comandos no terminal.

2.2. Atividade prática

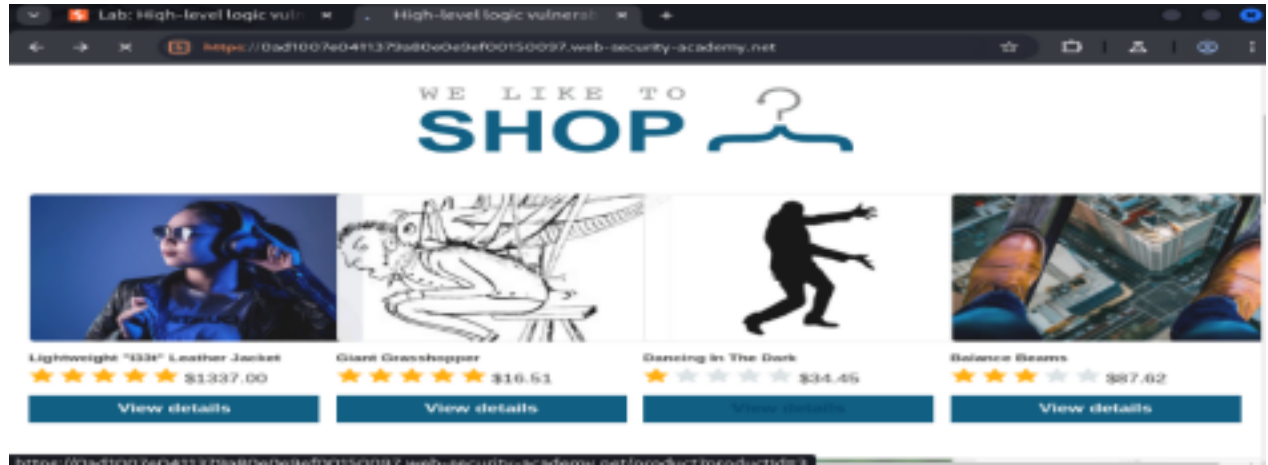
O objetivo desta atividade é realizar as 4 tarefas propostas no PortSwigger

2.3. Atividade 1 - Vulnerabilidade lógica de alto nível

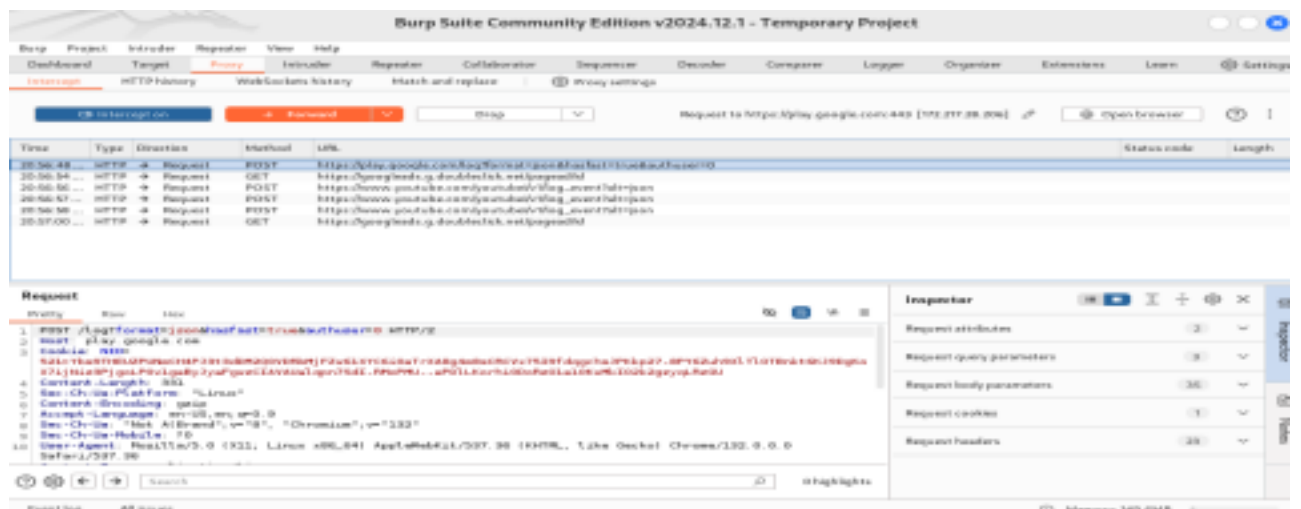
Passo 1 – Entre com seu login e senha no PortSwigger no site: <https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws-high-level> e clique em acesse o laboratório



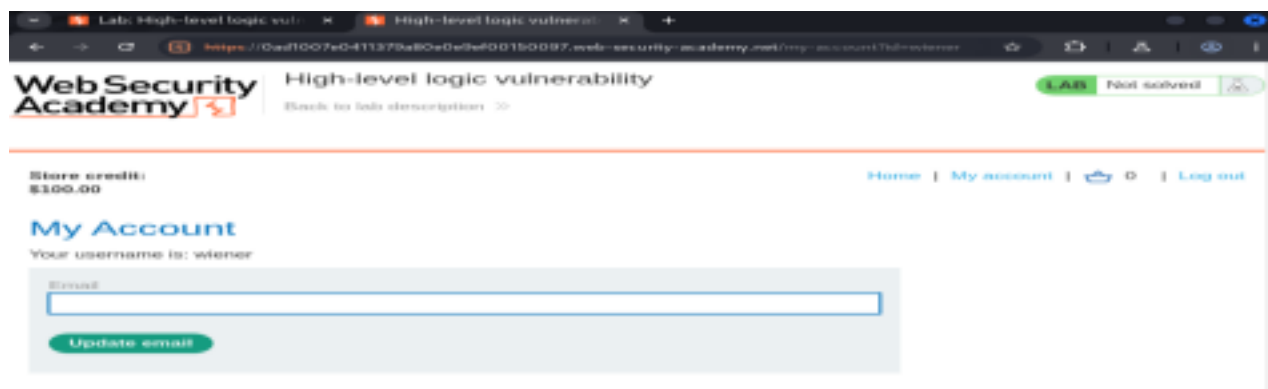
Passo 2 – Vai aparecer o site: <https://0a7e00f603204e51809258ad00f20041.web-security-academy.net/>



Passo 3 – Abra o Burp Community vá até Proxy clique em Intercept e depois em Intercept On caso esteja em off, sempre clique em forward para que a página seja carregada em seu navegador

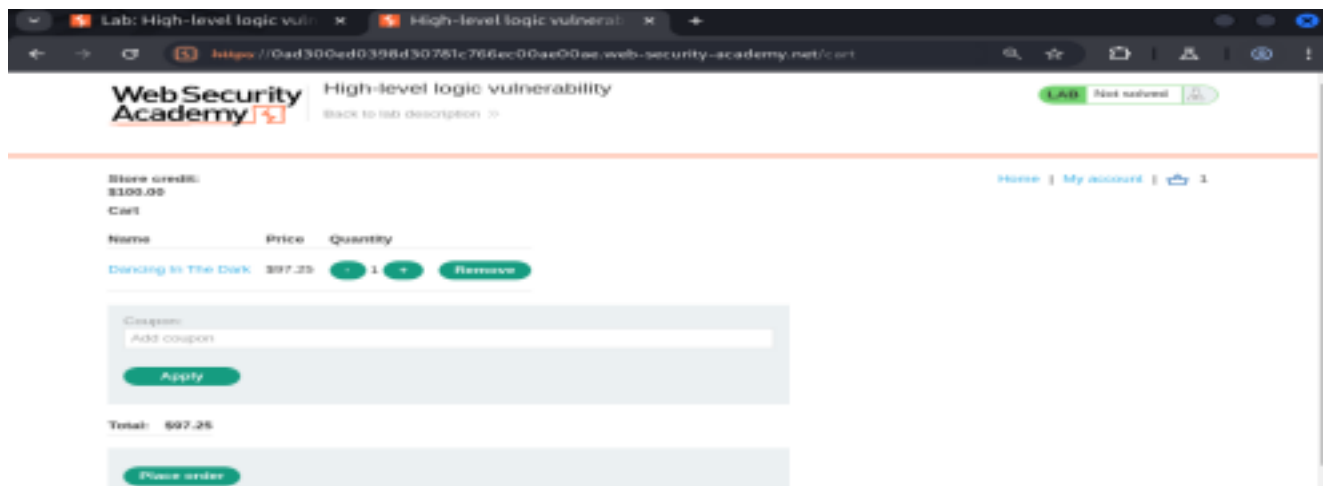


Passo 4 – Acesse My account e coloque no usuário wiener e no password peter, estará logado no usuário wiener e com \$ 100 dólares disponíveis para gastar.



3

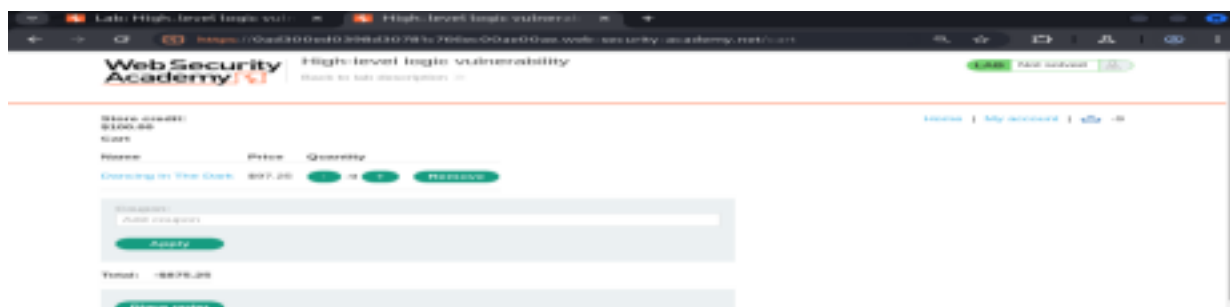
Passo 5 – Agora clique em Home e escolha o produto Dancing in the Dark e clique add to cart, aparece no carrinho o item que selecionou.



Passo 6 – Vá até o Burp e clique em http history e clique com o botão esquerdo em /cart e depois em Send to Repeater, agora colocaremos na quantidade um valor de – 10, clique em Send e atualize sua página.

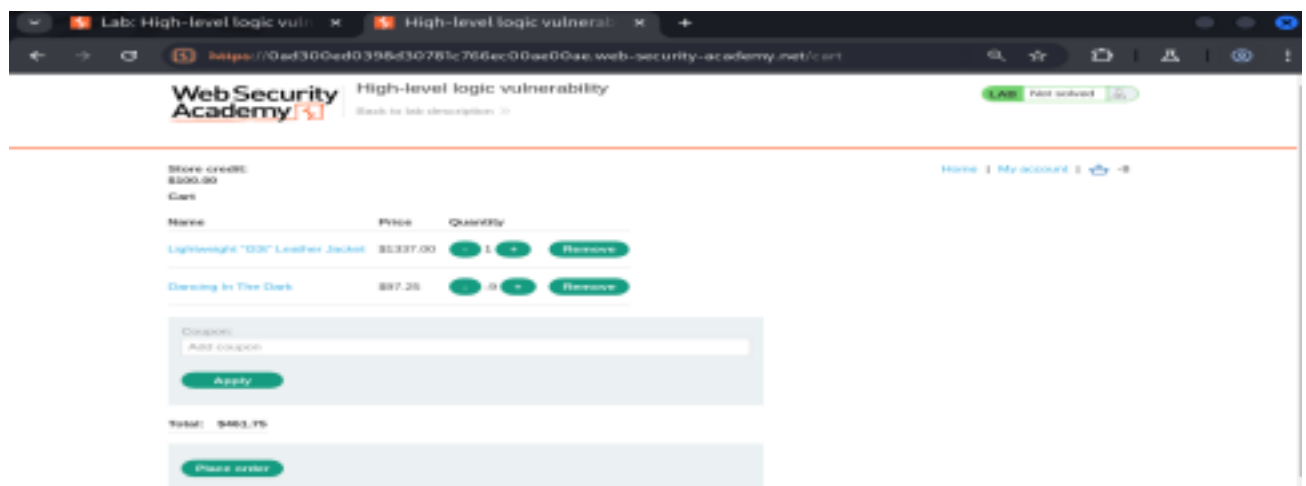


Passo 7 – No carrinho mostra um número negativo de -9 e o preço está negativo também como se a loja estivesse te devendo este valor.

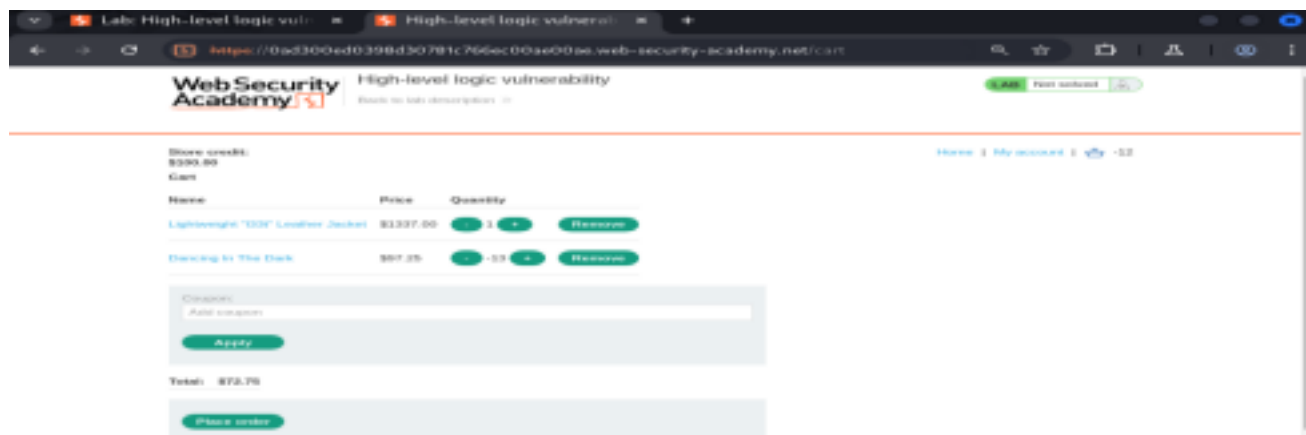


4

Passo 8 – Clique em Home e escolha o produto Lightweight “I33t” Leather Jacket, clique em add to cart, agora clique no carrinho



Passo 9 – No Burp clique em Repeater com a quantidade desejada até que o valor fique positivo e menor que \$ 100 e clique em place order



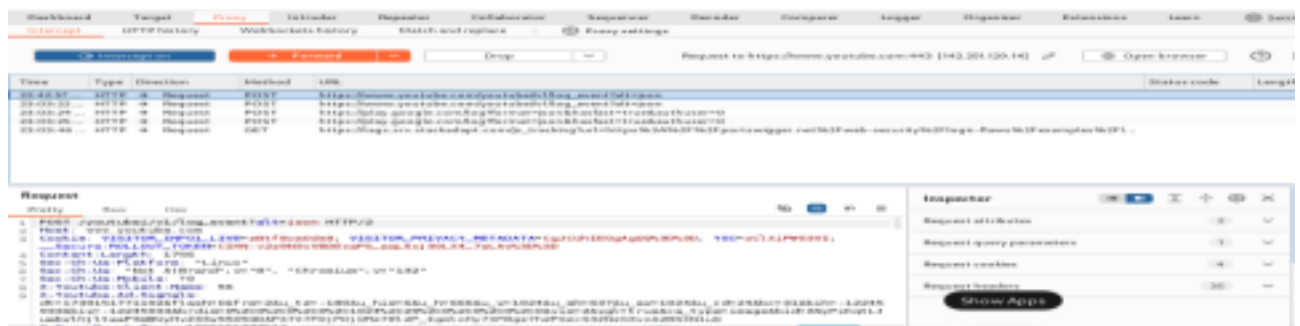
Passo 10– O laboratório está concluído



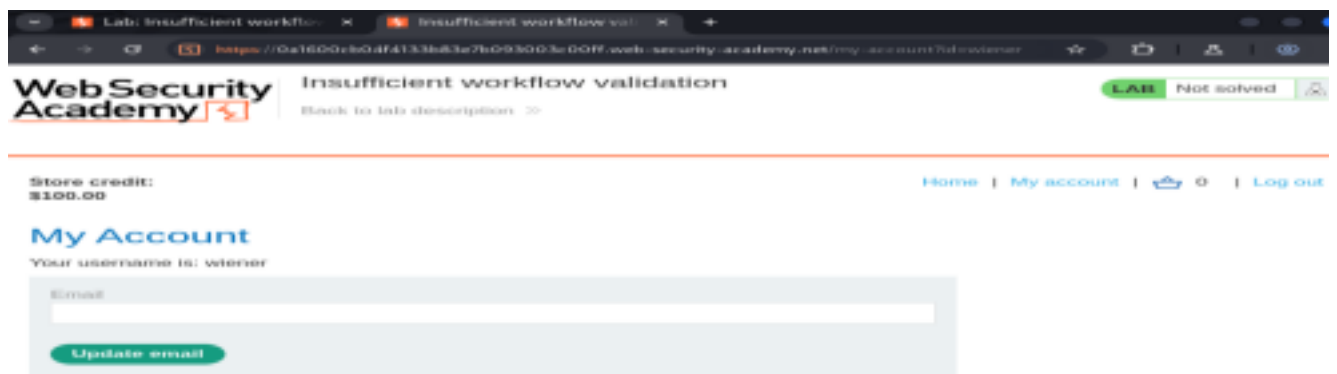
5

2.4. Atividade 2 – Validação de fluxo de trabalho insuficiente

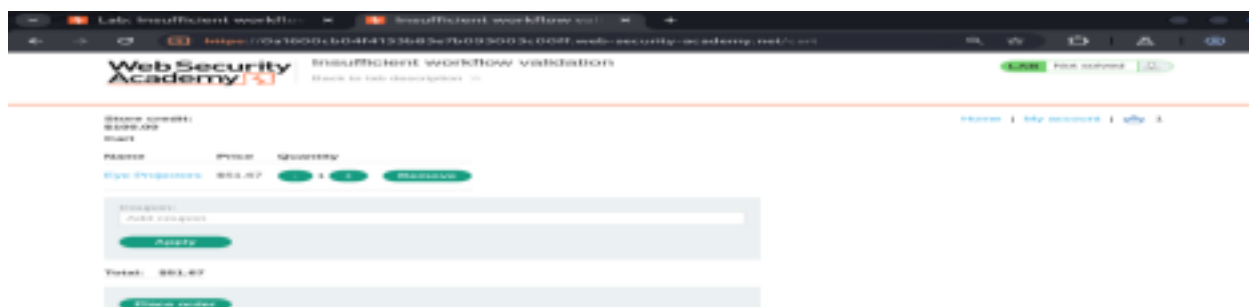
Passo 1 – Abra o Burp Community vá até Proxy clique em Intercept e depois em Intercept On caso esteja em off, sempre clique em forward para que a página seja carregada em seu navegador



Passo 2 – Acesse My account e coloque no usuário wiener e no password peter, usuário logado com \$ 100 de crédito

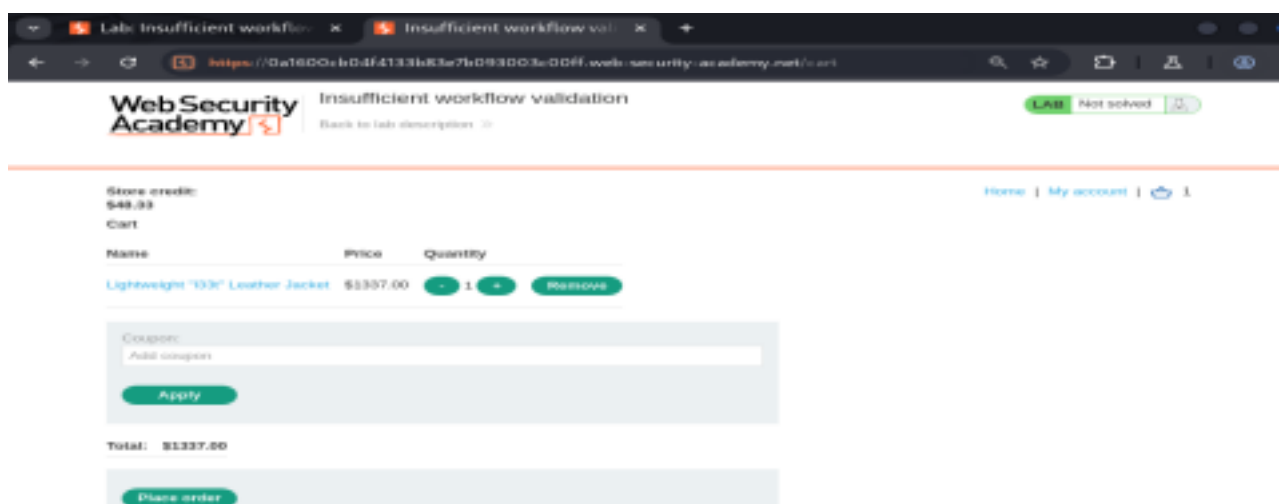


Passo 3 – Escolha o eye projectors e clique em add cart, clique no carrinho e depois em place order.



6

Passo 4 – Clique em Home e escolha o produto Lightweight "I33t" Leather Jacket e clique em add cart, o carrinho tem \$ 49.33 e o produto Lightweight "I33t" Leather Jacket custa \$1337.00



Passo 5 – Volte ao Burp Community na aba repeater e clique em Send



Passo 6 – Clique em atualizar e o laboratório estará concluído



7

2.5. Atividade 3 – Falha lógica de dinheiro infinito

Passo 1 - Abra o Burp Community vá até Proxy clique em Intercept e depois em Intercept On caso esteja em off, sempre clique em forward para que a página seja carregada em seu navegador



Passo 2 – Faça o login wiener e senha peter em My account e aparecerá a tela do usuário wiener.



Passo 3 – Clique em Gift Card e clique em add cart, depois clique no carrinho



8

Passo 4 – Clique em home e cadastre no signup com o e-mail s0mm3r@hacker.com e clique em signup e utilize o cupom SIGNUP30 no checkout e clique em place order.



Passo 5 – Clique no carrinho no espaço de Coupon SIGNUP30 e clique em apply, depois clique em place order e copie o código.



Passo 6 – Em my account no campo de gift card digite o código informado e clique em Redeem você terá um crédito de \$ 103.00



Passo 7 – No Burp em proxy Http History localize POST /gift-card, pegue o mesmo código já informado EjS3TZcS6c e vá até project options, clique em Add, clique em Scope em URL

clique em Include all urls, em Details, clique em Add Raise macro, clique em Add, selecione /cart/coupon, /cart/checkout, /cart/order-confirmation/order-confirmation e /gift-card e clique em Ok, No Macro Editor clique no cart/order-confirmation/order-confirmation e clique em configure macro item, clique em Add no parameter name digite gift-card, copie o código no td, depois clique em Ok e depois Ok novamente



Passo 8 – Depois vá até o /gift-card no Macro Editor clique em configure item em gift card selecione derive from prior response e response 4, depois clique em ok, depois clique em test macro, receberá um status 302 na URL /gift-card vá até request e copie o novo código de gift card JmTrQd0OvL depois clique 3 vezes em ok



Passo 9 – Clique em Proxy Http History, encontre /my-account, em request clique com o botão direito do mouse e selecione Send to Intruder, clique na aba do Intruder, clique na guia positions, clique no botão clear, selecione o attack type para sniper, clique na guia payloads, em payloads sets, na guia payloads type escolha null payloads, em payloads Options em Generate coloque 412, depois vá na guia Options em numbers of threads digite 1e clique em start attack, se clicar em atualizar seu browser seu dinheiro vai aumentar, depois que o ataque terminar terá \$ 1345.00, clique em home e clique no produto Lightweight “l33t” Leather Jacket, clique em add to cart, clique no carrinho e depois place order



Passo 10 – O laboratório foi finalizado com sucesso.



2.6. Atividade 4 – Bypass de autenticação via máquina de estado com falha

Passo 1 – Abra o Burp Community vá até Proxy clique em Intercept e depois em Intercept On caso esteja em off, sempre clique em forward para que a página seja carregada em seu navegador.



Passo 2 – Faça o login wiener e senha peter em My account e aparecerá a tela do usuário para selecionar a role selecione user e depois clique em select



Passo 3 – No Burp clique em Target, clique com o botão direito na URL, vá até Engagement Tools e clique em Discovery contente



12

Passo 4 – Clique em Control, clique em session is not running clique em Yes, clique em site map, clique na seta do lado esquerdo da url para expandir, clique em my account e aparecerá o usuário wiener



Passo 5 – Volte para a aba Control, veja os bytes transferidos, depois retorne a guia site map, clique em /admin depois feche a janela e clique em yes



Passo 6 – Na barra de endereço apague até academy.net e coloque /admin para entrar como administrador, clique em my account, clique em logout, vá até o burp clique em proxy, clique no botão de intercept para ficar ligado, depois clique novamente em my account, depois clique em forward 3 vezes, depois na tela de login digite wiener e na senha peter e clique em login



Passo 7 – Clique em forward, depois no get/role-selector clique em drop, depois na barra de endereço apague a informação role-selector e clique em atualizar, depois clique em forward duas vezes e no browser clique em admin panel depois desative a intercept para ficar desligado, depois delete o usuário carlos e concluirá o laboratório



Passo 8 – O laboratório foi concluído



14

2.7. Análise dos Resultados:

Foi realizada a instalação do Burp Community no Kali Linux

Interpretação dos resultados:

- 1) Na Atividade 1 - Vulnerabilidade lógica de alto nível podemos utilizar a manipulação da quantidade do carrinho colocando número negativo para conseguir comprar os produtos com um preço muito menor do que eles realmente custam, com \$ 72.76

consegui comprar um dancing in the dark que custava \$ 97,25 e um Lightweight "I33t" Leather Jacket que custava 1337.00.

- 2) Na Atividade 2 - Validação de fluxo de trabalho insuficiente: temos \$100 dólares e compramos um produto que custa \$ 51.67 sobrando \$ 48.33 e queremos comprar o produto Lightweight "I33t" Leather Jacket que custa 1377.00 adicione ao carrinho, interceptando esta comunicação do carrinho e enviando novamente a requisição consegue comprar a jaqueta mesmo sem ter saldo suficiente para isso.
- 3) Na Atividade 3 - Falha lógica de dinheiro infinito: utilizamos o cupom de desconto para gerar dinheiro e conseguir comprar qualquer produto do site, porque enviamos a requisição e nosso dinheiro sempre vai aumentado por isso que a falha se chama falha lógica de dinheiro infinito.
- 4) Na Atividade 4 - Bypass de autenticação via máquina de estado com falha: o acesso ao painel do administrador é realizado através da manipulação do login de um usuário comum ignorando a autenticação, tendo total acesso como se fosse administrador inclusive para excluir usuários

2.8. Mitigação:

- 1) No laboratório 1 não permitir que se utilize números negativos para a compra de produtos porque não existe comprar -2 produtos o campo tem que fazer a validação que ele seja sempre maior que 0;
- 2) No laboratório 2 temos que validar sempre o carrinho para que o cliente não compre algo que ele não tenha saldo suficiente para pagar;
- 3) No laboratório 3 a validação dos cupons de desconto para serem utilizados corretamente sem a possibilidade de ele gerar saldo infinito para o cliente, fazer esta validação é muito importante.
- 4) No laboratório 4 fazer o controle de autenticação para que os usuários não consigam acesso administrativo ao sistema, com um login e senha que não tem autorização para este acesso.

15

3. Considerações finais

Nesta sala, exploramos técnicas Pentest em Aplicações Web com o software Burp Suite Community para manipular algumas requisições, utilizando o Repeater para enviar requisições automaticamente, o Intruder para startar o ataque dos payloads e forçar alguns erros, também utilizamos o browser para conseguir ter acesso administrativo do site mesmo logando com um usuário comum.

As principais lições aprendidas incluem:

- 1) A validação de entrada nos campos é muito importante para que não haja nenhum tipo de manipulação
- 2) O fluxo de trabalho tem que ser muito bem organizado e validado para que o usuário não possa pular partes do processo e conseguir finalizar alguma compra sem pagar.
- 3) A autenticação é muito importante para que usuários comuns não possam ter acesso

de administrador, este acesso é crucial e deve ser protegido contra usuários não autorizados, fazendo validações constantes.

Foi verificado que é bem fácil alterar os parâmetros no browser, o Burp também é bem fácil de utilizar e tem recursos que deixam a manipulação do site ainda mais fácil como o Repeater e o Intruder para os payloads.

4. Referências

Site: <https://portswigger.net/web-security/information-disclosure/exploiting/lab/infoleak-in-error-messages>

Site: <https://portswigger.net/web-security/information-disclosure/exploiting/lab/infoleak-via-backup-files>

Site: <https://portswigger.net/web-security/information-disclosure/exploiting/lab/infoleak-in-version-control-history>

Site: <https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws/authentication-bypass-via-flawed-state-machine>